

Access Control Mistake	One-Line Fix / Prevention Tip
1. Trusting only the frontend for permissions	Always validate user permissions on the server , not just in the UI.
2. Insecure Direct Object Reference (IDOR) (e.g., changing an order ID in the URL to view another user's data)	Verify that the requested resource belongs to the authenticated user before returning it.
3. Missing role-based access checks (e.g., customers accessing admin pages)	Implement Role-Based Access Control (RBAC) and check roles on every protected request.
4. Using predictable resource IDs without authorization checks	Don't rely on hidden or sequential IDs; always perform authorization checks before granting access.
5. Not expiring sessions or authentication tokens	Set appropriate session/token expiration times and invalidate them on logout or password changes.